# Attacks and Exploits I

**Malware and Password Attacks**

M. Shehryar Raza

linkedin.com/in/ms-raza1

DOMAIN 2.0: THREATS, VULNERABILITIES, AND MITIGATIONS

# Attack Landscape Overview

Understanding attack vectors is fundamental to the real-world threat analysis. This week focuses on two primary categories of attacks that represent the most common threat vectors organizations face today. Each category encompasses specific techniques that security professionals must identify, analyze, and mitigate effectively.

## Malware Attacks

- Viruses and Worms
- Trojans and RATs
- Ransomware
- Spyware and Keyloggers
- Rootkits
- Logic Bombs
- Bloatware

## Password Attacks

- Brute Force
- Dictionary Attacks
- Password Spraying
- Credential Stuffing
- Wordlist Attacks
- Pass-the-Hash

# What is Malware?

Malicious Software – Any program or code designed to cause harm, bypass controls, or enable unauthorized access

Malware classification helps security professionals identify threats based on their behavior patterns. Understanding how malware propagates and what functions it performs enables more effective detection and response strategies.

## Classification by Propagation

- **Virus:** Self-replicating; requires host program and human action to spread
- **Worm:** Self-replicating; spreads independently across networks without user intervention

## Classification by Function/Payload

- **Trojan:** Disguised as legitimate; does not self-replicate
- **Ransomware:** Encrypts data and demands payment
- **Spyware:** Secretly monitors user activity
- **Keylogger:** Captures keystrokes
- **Rootkit:** Hides presence; enables privileged access
- **Logic Bomb:** Triggers on specific condition
- **RAT:** Remote administration tool used maliciously
- **Bloatware:** Unwanted software with security and performance impact

# Self-Replicating Malware

## Viruses and Worms

The fundamental difference between viruses and worms lies in their propagation mechanisms. This distinction is critical for the Security+ exam and determines appropriate defensive strategies. While both are self-replicating threats, their behavior patterns require different detection and mitigation approaches.

| Attribute | Virus | Worm |
|---|---|---|
| Requires host program | Yes | No |
| Requires user action | Yes | No |
| Spread mechanism | Infected files, removable media | Network, email auto-send |
| Modern prevalence | Declining | High |

> **Key Distinction for Exam:** Virus = Needs you to do something. Worm = Needs nothing; spreads automatically.

*Example Context:* WannaCry (2017) represented a sophisticated worm with ransomware payload that exploited SMB vulnerabilities to spread rapidly across networks worldwide.

# The Deceptive Inviter

## Trojans and Remote Access Trojans (RATs)

Trojans represent a significant threat vector because they exploit human psychology rather than technical vulnerabilities. Unlike viruses and worms, Trojans rely entirely on social engineering to gain initial access. Their disguise as legitimate software makes them particularly dangerous, as traditional security awareness often focuses on obvious threats.

### Trojan Characteristics

- Disguised as legitimate software or files
- Does NOT self-replicate or spread independently
- Requires user installation or execution
- Often serves as backdoor or downloader for additional payloads

### Remote Access Trojan (RAT)

- Provides attacker with remote control capabilities
- File transfer, screen viewing, webcam access
- Often persists through system reboots
- Can disable security software and create backdoors

### Common Delivery Methods

Fake software updates

Cracked or pirated software

Phishing email attachments

Malicious browser extensions

# The Silent Observer

## Spyware and Keyloggers

Spyware and keyloggers represent persistent surveillance threats that operate silently in the background. Unlike ransomware that announces its presence, these tools are designed for stealth, collecting sensitive information over extended periods. Their covert nature makes detection challenging, often requiring behavioral analysis rather than signature-based detection.

### Spyware Characteristics

- Secretly monitors user activity without consent
- Collects browsing history, credentials, and documents
- May include screen capture and clipboard monitoring
- Often bundled with free software or browser extensions
- Transmits collected data to remote servers

### Keylogger Threats

- Hardware-based (USB device) or software-based
- Captures every keystroke typed by user
- Primary targets: passwords, credit cards, personal communications
- Can bypass on-screen keyboards
- Difficult to detect without specialized tools

### Indicators of Compromise

Unexpected system slowdown or performance degradation

Increased network activity during idle periods

Unusual outbound connections to unknown IP addresses

# The Hidden Threat

## Rootkits

Rootkits represent the most sophisticated form of malware because they operate at the deepest system levels. By compromising the operating system itself, rootkits can hide their presence and the presence of other malware from security tools. This makes them exceptionally dangerous and difficult to remediate.

**Definition:** Malware designed to hide its presence and maintain privileged access while concealing its activities and other malware from security tools.

### Application Level

Hooks into APIs and application processes - easiest to detect and remove

### Kernel Level

Modifies OS kernel functions - very difficult to detect

### Bootkit

Infects bootloader - loads before OS starts

### Firmware

Infects hardware firmware - survives OS reinstall

### Why Rootkits Are Dangerous

- Survives system reboots and restarts
- Hides processes, files, and registry keys from view
- Disables or evades security software
- Extremely difficult to detect and remove

> **Detection Challenge:** If a rootkit controls what the operating system reports to security tools, you cannot trust OS-level detection. This requires specialized rootkit detection tools or bootable forensic environments.

# Time-Based and Unwanted Software

## Logic Bombs and Bloatware

While seemingly different, logic bombs and bloatware both represent threats that organizations often overlook. Logic bombs are intentional sabotage mechanisms, while bloatware creates unintended security vulnerabilities. Both expand the attack surface and require proactive management.

### Logic Bomb Characteristics

A logic bomb is malicious code that remains dormant until specific conditions are met, then executes its destructive payload.

- Code executes when specific condition is satisfied
- Triggers: date/time, user action, or absence of expected event
- Often planted by insiders with privileged access
- Difficult to detect during code review
- Can cause massive damage when activated

**Example:** Disgruntled employee sets payroll system to corrupt critical databases on their departure date, ensuring discovery only after they've left the organization.

### Bloatware Security Risks

Pre-installed, often unnecessary software that comes bundled with systems or applications.

- Expands attack surface unnecessarily
- Rarely receives security patches
- May contain default or hardcoded credentials
- Consumes system resources
- Creates hidden dependencies

**Mitigation:** Application allow-listing, baseline security configurations, and regular software inventory audits.

# Malware Attack Comparison

## Comprehensive Matrix for Exam Review

Understanding the differences between malware types is essential for the Security+ exam. This comprehensive comparison highlights key characteristics that distinguish each type, enabling you to identify threats based on behavioral descriptions in exam scenarios.

| Malware Type | Propagation | Primary Purpose | Persistence | Detection Difficulty |
|---|---|---|---|---|
| Virus | File infection | Damage, replication | Infected files | Medium |
| Worm | Network | Replication, payload delivery | Memory, services | Medium |
| Trojan | User install | Backdoor, downloader | Registry, scheduled tasks | Low-Medium |
| Ransomware | Trojan/worm | Extortion | Encrypted files | Low (obvious impact) |
| Spyware | Software bundle | Surveillance | Browser, system hooks | Medium |
| Keylogger | Trojan/rootkit | Credential theft | Kernel, hardware | Medium-High |
| Rootkit | Exploit, Trojan | Hide presence | Boot, kernel, firmware | Very High |
| Logic Bomb | Planted by insider | Sabotage | Application code | Very High (before trigger) |
| RAT | Trojan | Remote control | Service, registry | Medium |

**Exam Relevance:** Be able to differentiate malware types based on behavioral descriptions. Focus on propagation method, persistence mechanism, and primary objective.

# What Happens After Malware is Installed?

## Transition from Malware to Password Attacks

Malware installation is rarely the attacker's end goal - it's a means to an end. Once malware gains a foothold on a system, attackers typically pivot to credential theft and lateral movement. Understanding this progression is crucial for comprehensive threat analysis and defense-in-depth strategies.

The relationship between malware and password attacks represents a critical attack chain. Keyloggers, spyware, and RATs all exist primarily to steal credentials, which then enable attackers to conduct password attacks against additional systems.

## Password Attack Categories

### Online Attacks

Direct interaction with authentication system - attempts visible in logs

### Offline Attacks

Cracking extracted password hashes - no detection possible until credentials used

### Pass-the-Hash/Replay

Using credential without cracking - bypasses password entirely

# Brute Force – Try Every Combination

Brute force attacks represent the most straightforward but computationally expensive password attack method. While theoretically guaranteed to succeed given unlimited time and resources, modern defensive controls and password complexity requirements significantly reduce their effectiveness. However, advances in computing power continue to make brute force attacks viable against weak passwords.

**Definition:** Attempting every possible character combination systematically until the correct password is discovered.

## The Mathematics

- 8-character lowercase only: $26^8$ = 208 billion combinations
- 8-character full complexity (95 characters): $95^8$ = 6.6 quadrillion combinations
- 10-character full complexity: $95^{10}$ = 59.8 quintillion combinations

## Modern Reality

- GPU clusters: Billions of guesses per second
- Cloud cracking services: Rent massive compute power
- Short or simple passwords cracked in minutes to hours
- Complex passwords not sufficient protection alone

## Mitigation Strategies

- **Account lockout policies:** Limit failed attempts (e.g., 5 attempts then lockout)
- **Rate limiting:** Increase delay between authentication attempts
- **CAPTCHA:** Prevent automated attack tools
- **Multi-Factor Authentication (MFA):** Blocks 99.9% of automated attacks
- **Password length requirements:** Minimum 12-14 characters

> Even with account lockout, distributed attacks from multiple IP addresses can evade detection while conducting systematic brute force attempts.

# Working Smarter, Not Harder

## Dictionary and Wordlist Attacks

Dictionary and wordlist attacks exploit predictable human behavior in password selection. Rather than trying every possible combination, these attacks focus on passwords that people actually choose. This dramatically reduces the attack space and increases success rates, making them far more efficient than pure brute force.

### Dictionary Attack

Attempts words from dictionary files containing common passwords, names, sports teams, and pop culture references. Without complexity requirements, success rate reaches 40-60% because users choose memorable, simple passwords.

### Wordlist Attack

Uses breached password databases like rockyou.txt (14 million real passwords from actual breaches). Includes common mutations like Password1, Summer2024, Admin@123 that meet basic complexity requirements.

### Why These Attacks Are Effective

- Humans choose memorable passwords over random strings
- Massive password reuse across multiple sites and services
- Password complexity rules create predictable patterns
- Common substitutions (@ for a, 1 for i, $ for s) are well-known
- Seasonal and year-based passwords are extremely common

### Effective Mitigations

- **Breached password detection:** Block passwords found in breach databases
- **Complexity AND length:** Require both diverse characters and sufficient length
- **Password managers:** Generate and store truly random passwords
- **User education:** Explain why common passwords fail

# Password Spraying – Low and Slow

Password spraying represents an evolution in attack methodology that specifically evades traditional defensive controls. By understanding how account lockout policies work, attackers can conduct large-scale password attacks while remaining undetected. This technique has become increasingly common in enterprise environments.

## The Problem with Brute Force

- Many failed attempts on one account triggers lockout
- Generates obvious security alerts
- Easily detected by security monitoring
- Limited attempts before blocking

## Password Spraying Solution

**Don't try many passwords on one account. Instead, try one password on many accounts.**

## Attack Methodology

1. Select 1-3 extremely common passwords (Password123, Summer2024, CompanyName1)
2. Attempt on thousands of user accounts in the organization
3. Wait 30-60 minutes between attempts per account
4. Distribute attempts across multiple IP addresses
5. Harvest successful credentials for further exploitation

## Why Password Spraying Works

**Statistical guarantee:** In any large organization, some percentage of users will choose weak, common passwords despite policies

**Evades lockout:** Single failed attempt per account doesn't trigger account lockout thresholds

**Low detection:** Traditional monitoring focuses on multiple failures per account, not patterns across accounts

**Mitigation strategies:** Ban common passwords proactively, implement monitoring for single failed attempts across many accounts (lateral movement detection), enforce multi-factor authentication, and use conditional access policies.

# Credential Stuffing – Password Reuse Epidemic

Credential stuffing exploits one of the most widespread security vulnerabilities: password reuse. As data breaches expose billions of credentials, attackers leverage this treasure trove to compromise accounts across the internet. The average user maintains over 100 online accounts, making unique passwords nearly impossible without password managers.

## The Problem

01

Average user has 100+ online accounts

02

Impossible to remember 100+ unique passwords

03

Solution: Reuse same password across sites

04

Result: One breach compromises ALL accounts

## Attack Flow

1. Attacker obtains credential dump from major breach (LinkedIn 2012: 117M accounts, Yahoo 2013: 3B accounts, Collection #1: 773M emails)
2. Automated bots test credential pairs on other high-value sites (banking, email, corporate systems)
3. Successful login confirms credential reuse
4. Account takeover and potential identity theft

## Attack Scale

- **Available credentials:** Billions on dark web marketplaces
- **Attack velocity:** Millions of attempts per hour via botnets
- **Success rate:** 0.1-2% seems small, but at scale represents millions of compromised accounts
- **Detection difficulty:** Appears as legitimate login from correct credentials

> **Critical Mitigation:** Multi-factor authentication blocks 99.9% of credential stuffing attacks. Breached password detection and passwordless authentication provide additional protection layers.

# Pass-the-Hash – No Password Required

Pass-the-hash attacks represent a fundamental flaw in certain authentication protocols. Unlike other password attacks that attempt to discover or crack passwords, pass-the-hash uses the password hash itself as a credential. This makes traditional password strength requirements irrelevant and highlights the importance of protocol-level security.

## The Environment: Windows Active Directory with NTLM Authentication

### How NTLM Works

1. User enters password at login
2. System calculates cryptographic hash of password
3. Hash is stored and used to prove identity
4. Hash is sent over network during authentication

### Hash Acquisition Methods

- LSASS memory dump using Mimikatz tool
- SAM database extraction from domain controller
- Network sniffing during NTLM authentication
- Cached credentials on compromised workstations

### The Attack

Attacker obtains NTLM hash through various extraction methods. The critical insight: **attacker doesn't need the actual password**. The hash itself serves as the credential.

The attacker then uses the stolen hash to authenticate directly to other systems. No password cracking required. No password knowledge needed at all.

### Why This Is Dangerous

- Hash equals credential in NTLM
- Password changes don't always invalidate stolen hash
- Works across entire network domain
- Enables lateral movement between systems

### Mitigation Strategies

**1**

**Credential Guard**

Virtualization-based security isolates credentials

**2**

**Restricted Admin Mode**

Prevents credential caching on remote systems

**3**

**Least Privilege**

Limit accounts with domain admin rights

**4**

**PAW Architecture**

Privileged Access Workstations for admin tasks

# IAM Controls Against Password Attacks

## Password Attack Mitigation Summary

Identity and Access Management (IAM) controls provide the primary defense against password-based attacks. Understanding which controls effectively mitigate specific attack types is essential for both exam scenarios and real-world security architecture decisions. Multi-layered defense is critical because no single control provides complete protection.

| Attack Type | Primary Mitigation | Secondary Mitigation |
|---|---|---|
| Brute Force | Account lockout policies | Rate limiting, CAPTCHA, MFA |
| Dictionary | Password complexity requirements | Breached password blocking, length requirements |
| Password Spraying | Ban common passwords proactively | Lateral anomaly detection, MFA |
| Credential Stuffing | Multi-Factor Authentication | Breached password detection, conditional access |
| Pass-the-Hash | Credential Guard (Windows) | Least privilege, PAW, Kerberos authentication |

**99.9%**

MFA Effectiveness

Multi-factor authentication blocks 99.9% of automated credential-based attacks according to Microsoft research

**81%**

Breach Attribution

Percentage of data breaches involving weak, default, or stolen passwords (Verizon DBIR)

**5**

Average Failed Attempts

Recommended account lockout threshold to balance security and usability

> **Key Takeaway:** Multi-factor authentication is the single most effective control against credential-based attacks. However, defense-in-depth requires multiple overlapping controls to address different attack vectors and failure scenarios.